SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY
COURSE CODE: CSA5101

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Scenario-Based : 20%

Total Marks: 50

Annexure A

Code of Conduct:

I **N.Akhshaya(192425129)** *certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: N.Akshaya

Annexure A

1. Secure Password Storage in Web Applications

A web application stores user passwords and needs to protect them against database breaches.

A. Explain why storing plaintext passwords is insecure.

B. Suggest a secure method for storing passwords and justify your choice.

A. Explain why storing plaintext passwords is insecure.

Storing passwords in plaintext means saving passwords in their original, readable form in a database. This is a serious security risk because anyone who gains unauthorized access to the database can easily read users' passwords.

The main problems are:

1. Password theft: Attackers can directly obtain users' passwords.
2. Account misuse: Hackers can log in to users' accounts without permission.
3. Multiple account attacks: Users often reuse passwords on different websites, so one database breach can affect several accounts.
4. Privacy loss: Attackers may access personal information, banking details, or confidential data.

Therefore, plaintext passwords should never be stored in a database.

B. Suggest a secure method for storing passwords and justify your choice.

A secure method is password hashing with a unique salt.

Password hashing converts a password into a fixed-length value called a hash. A salt is a random value added to the password before hashing.

Working procedure:

1. The user creates a password.
2. The system generates a unique salt.
3. The password and salt are processed using a secure password-hashing algorithm.
4. The salt and resulting hash are stored in the database.
5. During login, the system verifies the entered password against the stored hash.

Algorithms such as Argon2id, bcrypt, and scrypt are designed to make password cracking more difficult.

Justification: Even if attackers steal the database, they cannot directly read the original passwords. A unique salt also prevents identical passwords from producing identical stored hashes when different salts are used.

Conclusion: Salted password hashing protects user credentials and reduces the damage caused by database breaches.

2. Digital Signature for Document Authentication

A company wants to ensure that official documents sent electronically are authentic and unaltered.

A. Explain how digital signatures can be used in this scenario.

B. Justify how this method ensures both integrity and non-repudiation.

A. Explain how digital signatures can be used in this scenario.

A digital signature is a cryptographic technique used to verify the authenticity and integrity of electronic documents. It uses a private key for signing and a corresponding public key for verification.

Working procedure:

1. The sender prepares the official document.
2. A cryptographic hash of the document is generated.
3. The sender signs the hash using their private key.
4. The document and digital signature are sent to the receiver.
5. The receiver uses the sender's public key to verify the signature.
6. The receiver checks the document's hash to detect any changes.

For example, a company can digitally sign appointment letters, contracts, invoices, and official reports before sending them electronically.

B. Justify how this method ensures both integrity and non-repudiation.

1. Integrity: A digital signature helps detect changes to a document. If an attacker modifies even a small part of the document, the hash changes, causing signature verification to fail.

2. Non-repudiation: A valid digital signature provides evidence that the document was signed using the corresponding private key. This helps prevent the signer from denying the signature, provided the private key was securely controlled and the signer's identity was properly verified.

3. Authentication: The receiver can verify that the signature corresponds to the sender's public key, whose association with the sender should be established through a trusted certificate or other reliable method.

Conclusion: Digital signatures improve document security by helping verify the sender's identity, detect unauthorized modifications, and provide evidence of signing.

3. Preventing Replay Attacks in Online Transactions

An online payment system is vulnerable to replay attacks where attackers resend previously captured transactions.

A. Explain how replay attacks occur.

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

A. Explain how replay attacks occur.

A replay attack is a type of network attack in which an attacker captures a valid message and retransmits it later to perform an unauthorized or repeated action.

Example: A customer transfers ₹1,000 to another account through an online banking application. An attacker captures the transaction message and sends it again. If the banking system does not identify duplicate requests, the same transaction may be processed more than once.

Steps involved:

1. The user sends a valid transaction request.
2. The attacker captures the transaction message.
3. The attacker resends the captured message.
4. The system may process the request again if replay protection is missing.

Effects of replay attacks:

- Duplicate payments and financial losses.
- Unauthorized repetition of transactions.
- Loss of customer trust.
- Increased risk to online banking and e-commerce systems.

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

A suitable solution is to use unique nonces, timestamps, and Message Authentication Codes (MACs).

A nonce is a unique value used to identify a particular transaction or request.

Working procedure:

1. The system generates a unique nonce for a transaction.
2. The transaction message includes the nonce and a timestamp.
3. A MAC is generated using a secret key to protect the message's authenticity and integrity.
4. The receiver verifies the MAC and checks the timestamp.

5. The system checks whether the nonce has already been used.
6. If the nonce is repeated or the request has expired, the transaction is rejected.

Justification:

- Nonce: Prevents the same transaction request from being accepted repeatedly.
- Timestamp: Limits how long a captured message remains valid.
- MAC: Detects unauthorized modifications and verifies that the message was created by someone possessing the secret key.

The system must securely track used nonces and verify them before processing a transaction.

Conclusion: Combining nonces, timestamps, and MACs helps prevent replay attacks and makes online payment systems more secure.

4. Secure Communication over Public Wi-Fi

A user accesses sensitive information using a public Wi-Fi network without encryption.

A. Identify the risks involved in this scenario.

B. Recommend a secure communication method and justify how it protects user data.

A. Identify the risks involved in this scenario.

Public Wi-Fi is commonly available in places such as airports, railway stations, hotels, and cafes. If a user accesses sensitive information without encryption, attackers on the network may be able to intercept or manipulate the communication.

Major risks:

1. Data theft: Attackers may capture sensitive information transmitted without encryption.
2. Password theft: Login credentials may be exposed.
3. Man-in-the-middle attack: An attacker may position themselves between the user and the server to intercept or modify messages.
4. Session hijacking: Attackers may steal session information and attempt to access an account.
5. Fake Wi-Fi networks: Attackers may create networks that imitate legitimate public hotspots.
6. Privacy loss: Browsing information and other unprotected data may be exposed.

For example, entering banking credentials through an unencrypted connection may expose them to attackers who can monitor the network traffic.

B. Recommend a secure communication method and justify how it protects user data.

The recommended method is HTTPS using Transport Layer Security (TLS). A trusted Virtual Private Network (VPN) can provide additional protection on public Wi-Fi.

Working procedure of HTTPS/TLS:

1. The user connects to a website using HTTPS.
2. TLS authenticates the website using its digital certificate.
3. The browser and server establish secure session keys.
4. The data is encrypted before being transmitted.
5. The receiving system decrypts the data and processes it.

Security benefits:

- Confidentiality: Encryption prevents other network users from easily reading transmitted data.
- Integrity: TLS helps detect unauthorized changes to data during transmission.
- Authentication: Certificate validation helps the user verify the website's identity.
- Additional protection: A properly configured VPN encrypts traffic between the device and the VPN server, helping protect traffic on the local Wi-Fi network.

Justification: HTTPS/TLS protects communication between the browser and the website even when the Wi-Fi network itself is untrusted. However, users should avoid suspicious websites, heed certificate warnings, and keep their devices updated.

Conclusion: Using HTTPS/TLS and, where appropriate, a trusted VPN reduces the risks of data theft and interception on public Wi-Fi.

5. Data Integrity in Cloud Storage

An organization stores critical data in a cloud server and wants to ensure that the data is not altered.

A. Explain how hashing can be used to verify data integrity.

B. Suggest an additional mechanism to enhance trust and justify your answer.

A. Explain how hashing can be used to verify data integrity.

Hashing is a cryptographic process that converts data of any size into a fixed-length value called a hash or message digest. Even a small change in the original file should produce a different hash when a secure algorithm such as SHA-256 is used.

Working procedure:

1. The organization creates a file and calculates its hash.
2. The original hash is stored securely and separately from the file.
3. The file is uploaded to cloud storage.
4. When verification is required, the file is downloaded.
5. The organization calculates a new hash of the downloaded file.
6. The new hash is compared with the original hash.

If both hashes match, the file is consistent with the original data. If the hashes differ, the file may have been modified or corrupted.

Example: An organization stores an important financial report in the cloud. It calculates the SHA-256 hash before uploading the report. Later, it recalculates the hash after downloading the report. Matching hashes provide evidence that the file has not changed.

Advantages of hashing:

- Detects accidental data corruption.
- Helps identify unauthorized modifications.
- Supports verification of downloaded files.
- Provides an efficient way to compare large files.

Limitation: A hash alone does not prove who created the file. If an attacker can modify both the file and its stored hash, the comparison may not reveal the attack. Therefore, the original hash must be protected.

B. Suggest an additional mechanism to enhance trust and justify your answer.

An additional mechanism is a digital signature. It provides evidence of authenticity and helps verify the integrity of stored data.

Working procedure:

1. The organization calculates a cryptographic hash of the original file.
2. It signs the hash using its private key.
3. The file and digital signature are stored or transmitted.

4. When verification is required, the receiver uses the organization's public key to verify the signature.
5. The receiver also calculates the file's current hash and checks it against the signed hash.

Justification:

- Authenticity: The signature helps establish that the data was signed using the private key associated with the organization.
- Integrity: Changes to the file cause the hash comparison or signature verification to fail.
- Trust: The receiver can verify the signature without needing access to the organization's private key.
- Accountability: The signature provides evidence of signing, assuming the private key is protected and the identity is reliably verified.

The organization should also protect its private key and store trusted verification information securely.

Conclusion: Hashing helps detect changes in cloud-stored data, while digital signatures provide additional evidence of authenticity and integrity. Together, they improve trust and security in cloud storage.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand